

5. SUID (Set User ID) Abuse

SUID adalah salah satu topik yang paling sering muncul dalam Boot2Root.

Apa itu SUID?

Normalnya, program berjalan dengan hak akses user yang menjalankannya.

Contoh:

john menjalankan cat

↓

cat berjalan sebagai john

Namun jika sebuah file memiliki bit SUID:

`-rwsr-xr-x`

maka program tersebut berjalan dengan hak akses pemilik file.

Contoh:

`-rwsr-xr-x root root`

Artinya:

User biasa menjalankan program

↓

Program berjalan sebagai root

Inilah alasan SUID sering menjadi jalur privilege escalation.

Cara Mencari SUID

Perintah yang hampir selalu dijalankan saat enumerasi:

```
find / -perm -4000 2>/dev/null
```

Contoh hasil:

`/usr/bin/passwd`

`/usr/bin/su`

`/usr/bin/find`

`/usr/bin/vim`

Cara Membaca Hasil

Jangan panik melihat ratusan file.

Fokus pada:

Normal

Biasanya ada:

passwd
su
mount
umount
sudo

Ini sering memang diperlukan sistem.

Tidak Biasa

Contoh:

/opt/backup
/usr/local/bin/admin
/home/dev/test

Program custom jauh lebih menarik.

Karena sering dibuat dengan konfigurasi yang salah.

Langkah Analisis

Misal ditemukan:

/opt/backup

Pertanyaan:

Siapa pemiliknya?

ls -la /opt/backup

Contoh:

-rwsr-xr-x root root

Apa jenis filenya?

file /opt/backup

Contoh:

ELF 64-bit executable

String apa yang ada di dalamnya?

strings /opt/backup

Cari:

backup.sh
tar
cp
system

Ini sering memberi petunjuk.

Pola yang Sering Muncul di CTF

Program Memanggil Script

Misal hasil:

backup.sh

Artinya program SUID mungkin menjalankan script lain.

Periksa:

ls -la backup.sh

Tanya:

siapa pemiliknya?

siapa yang bisa menulis?

Program Memanggil Command Sistem

Misal:

tar
cp
cat

Terkadang developer memanggil command tanpa path absolut.

Contoh konsep:

system("tar backup")

Ini menarik karena program bergantung pada command eksternal.

Program Membaca File Sensitif

Misal:

cat /root/secret.txt

Karena berjalan sebagai root, program mungkin memiliki akses yang tidak dimiliki user biasa.

Binary Custom

Yang paling berbahaya biasanya:

/opt/admin
/usr/local/bin/backup
/home/dev/debug

Kenapa?

Karena bukan bagian standar Linux.

Developer sering membuat kesalahan seperti:

permission salah

validasi input buruk

memanggil shell

memanggil script eksternal

Checklist Saat Menemukan SUID

Untuk setiap file:

1. Apakah file standar Linux?
2. Apakah file custom?
3. Siapa pemiliknya?
4. Apakah writable?
5. Apa fungsi program?
6. Apakah memanggil command lain?
7. Apakah memanggil script?

Tools Analisis

Melihat informasi:

file binary

Melihat string:

strings binary

Melihat library:

ldd binary

Melihat permission:

ls -la binary

Contoh Studi Kasus CTF

Misal hasil:

```
find / -perm -4000 2>/dev/null
```

menghasilkan:

/usr/bin/passwd

/usr/bin/su

/opt/backup

Pemula:

Fokus ke passwd

Padahal:

passwd

sering normal.

Peserta berpengalaman:

Fokus ke /opt/backup

karena itu program custom dan lebih mungkin mengandung kesalahan konfigurasi.

Prioritas Enumerasi PrivEsc

Saat mendapatkan shell:

sudo -l

↓

SUID

↓

Cron

↓

Capabilities

↓

Writable files

↓

Services

Jadi ketika menemukan SUID, jangan langsung mencari "exploit". Mulailah dengan memahami:

Apa program ini?

Apa yang dilakukan?
Apa yang dipanggil?
Apakah ada konfigurasi yang salah?

Itulah pola pikir yang biasanya menghasilkan privilege escalation pada soal Boot2Root.

Materi berikutnya yang sangat sering keluar di LKS dan Boot2Root adalah Cron Job Abuse, yaitu cara menganalisis tugas terjadwal yang berjalan sebagai user lain atau root dan mencari salah konfigurasi yang dapat dimitigasi.